

Sthyra CRM — Developer Flow Diagrams

For: Software developers implementing Sthyra CRM · **Version:** 1.0

>

Ten flow diagrams showing the request flows, state machines, and data pipelines you will implement. Each diagram is paired with the architectural invariants that must hold in code. Colors follow `@sthyra-crm/tokens`: teal = control flow, amber = decisions/warnings/storage, dark = context.

1. Authentication Flow (OIDC → JWT → RBAC)

What happens on every login: federated IdP → Cognito token → API Gateway validation → Redis-cached principal → per-route RBAC.

User
(mobile or web)

Login attempt

Developer note:

- @sthira-crm/auth plugin does steps 6–9
- Idempotency-Key honored on mutating routes
- x-request-id propagated end-to-end

IdP: Okta / Entra / Auth0

redirect w/ code

OIDC authorization code

Exchange code → ID + access token
(Cognito user pool)

JWT: sub, email, org_id, role, tenant_id, exp

API Gateway validates:

- signature (JWKS)
- expiry
- audience

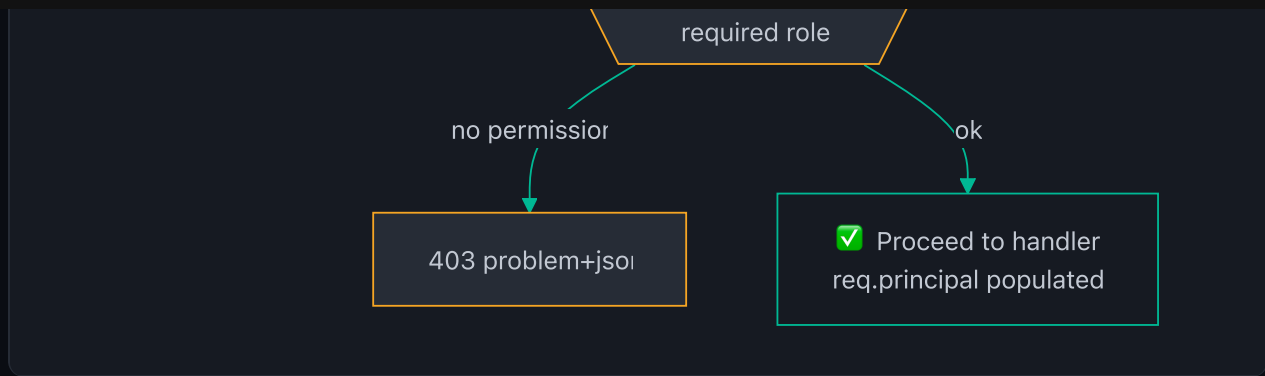
invalid

401 problem+jsor with trace_id

valid

Principal cached in Redi:
TTL 5 min

Service RBAC check
req.principal.role vs

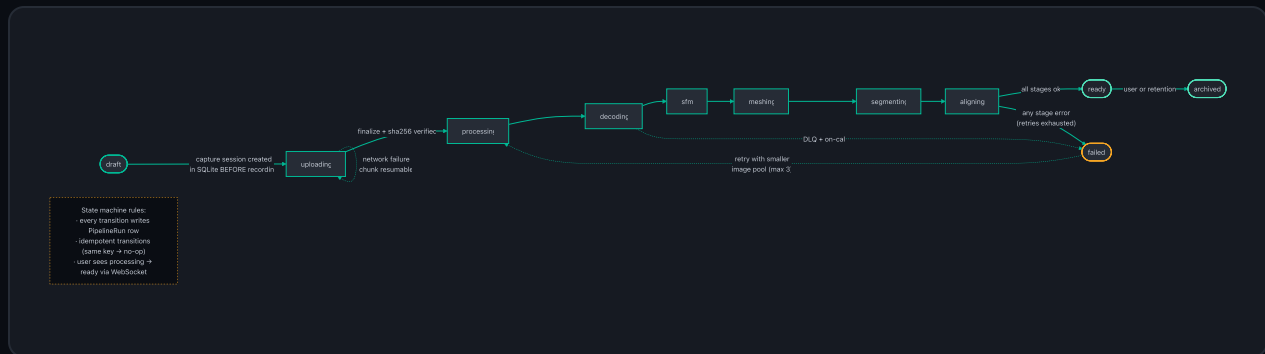


Developer rules:

- Use the `@sthyra-crm/auth` plugin — it does steps 6–9 (JWT validate, principal attach, 401/403 problem+json). Don't reimplement.
- Every mutating route honors `Idempotency-Key`; every error carries `trace\_id` (RFC 7807).
- Phase 2: service-to-service calls switch from bearer JWT to SPIFFE SVIDs ($TTL \leq 1\text{ h}$) — the plugin interface stays the same.

2. Capture Lifecycle State Machine

The capture goes draft → uploading → processing (5 sub-stages) → ready | failed | archived. This is the heart of the ingestion system.



Developer rules:

- `CaptureSession` row is inserted in SQLite **before** recording starts — crashes are recoverable.
- Every transition writes a `PipelineRun` row; transitions are idempotent (same key → no-op).
- Retry policy: SfM/MVS retry with a smaller image pool, max 3 attempts, then DLQ → on-call.
- User-visible state flips `processing` → `ready` via WebSocket push from realtime-gateway.

3. Offline-First Sync (Field Notes)

The field is offline ~40% of the day. The sync engine must never lose data and never duplicate.

Field user creates note
(no network)

Developer note:

- offline queue survives app kill (BGTaskScheduler/WorkManager)
- collision-safe: UUIDv7 + Lamport clock
- retry with exponential backoff, no data loss

SQLite (GRDB/Room)
LocalID = UUIDv7
Lamport ts

SyncEngine:
dirty records

yes

Upload batch:
clientId + contentHash
(idempotent)

Server:
contentHash exists

duplicate

new

no

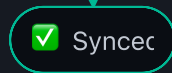
Return existing ServerID
(no duplicate created)

INSERT with ServerID
+ map LocalID → ServerID

Write mapping back
+ mark record synced

Fetch since cursor

Fetch since cursor
→ upsert local

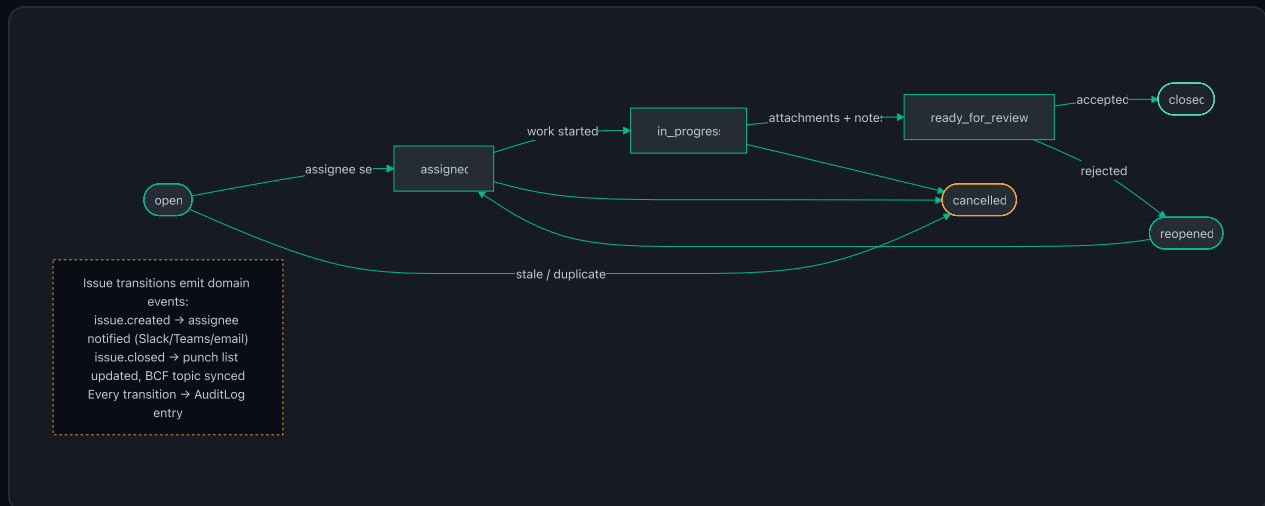


Developer rules:

- LocalID = UUIDv7 (time-ordered, collision-safe); Lamport timestamps for ordering.
- Idempotency via `clientId + contentHash` — server returns existing ServerID on duplicate.
- Background upload via BGTaskScheduler (iOS) / WorkManager (Android); survives app kill and airplane mode.
- On reconnect: pull-by-cursor (since `lastSyncCursor`) → upsert locally.

4. Issue Workflow State Machine

Issues flow open → assigned → in_progress → ready_for_review → closed, with reopen and cancel paths.

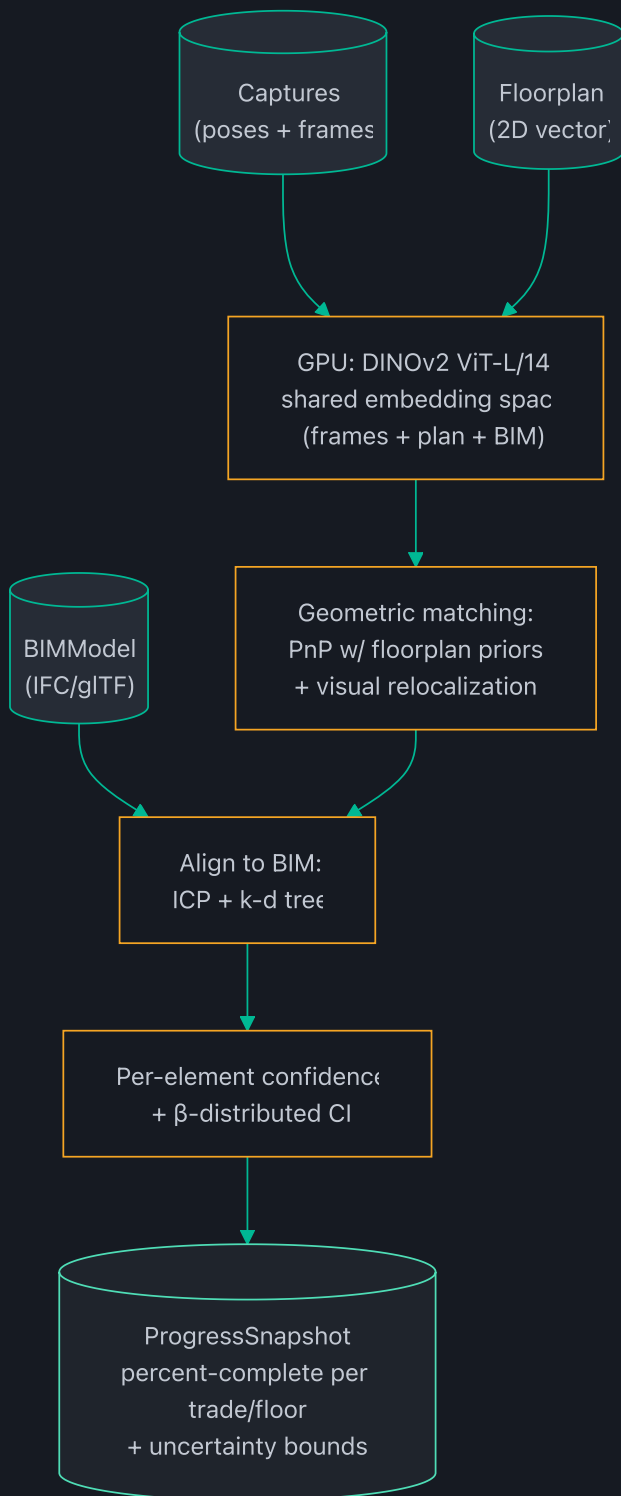


Developer rules:

- Every transition emits a domain event → notify (Slack/Teams/email) + AuditLog entry.
- BCF 3.0 topic sync on close (Sthyra CRM Model ↔ external BIM tools).
- Punch-list and progress rollups consume `issue.closed` events — never poll.

5. BIM-vs-Reality Alignment Pipeline

The math behind Sthyra CRM Track: how captures, floorplans, and BIM models fuse into per-trade percent-complete.



Quality gate: percent-complete accuracy
 $\pm 3\%$ abs / $\pm 5\%$ rel vs hand-counted baseline.
Reproducible: seeded runs, artifacts persisted.

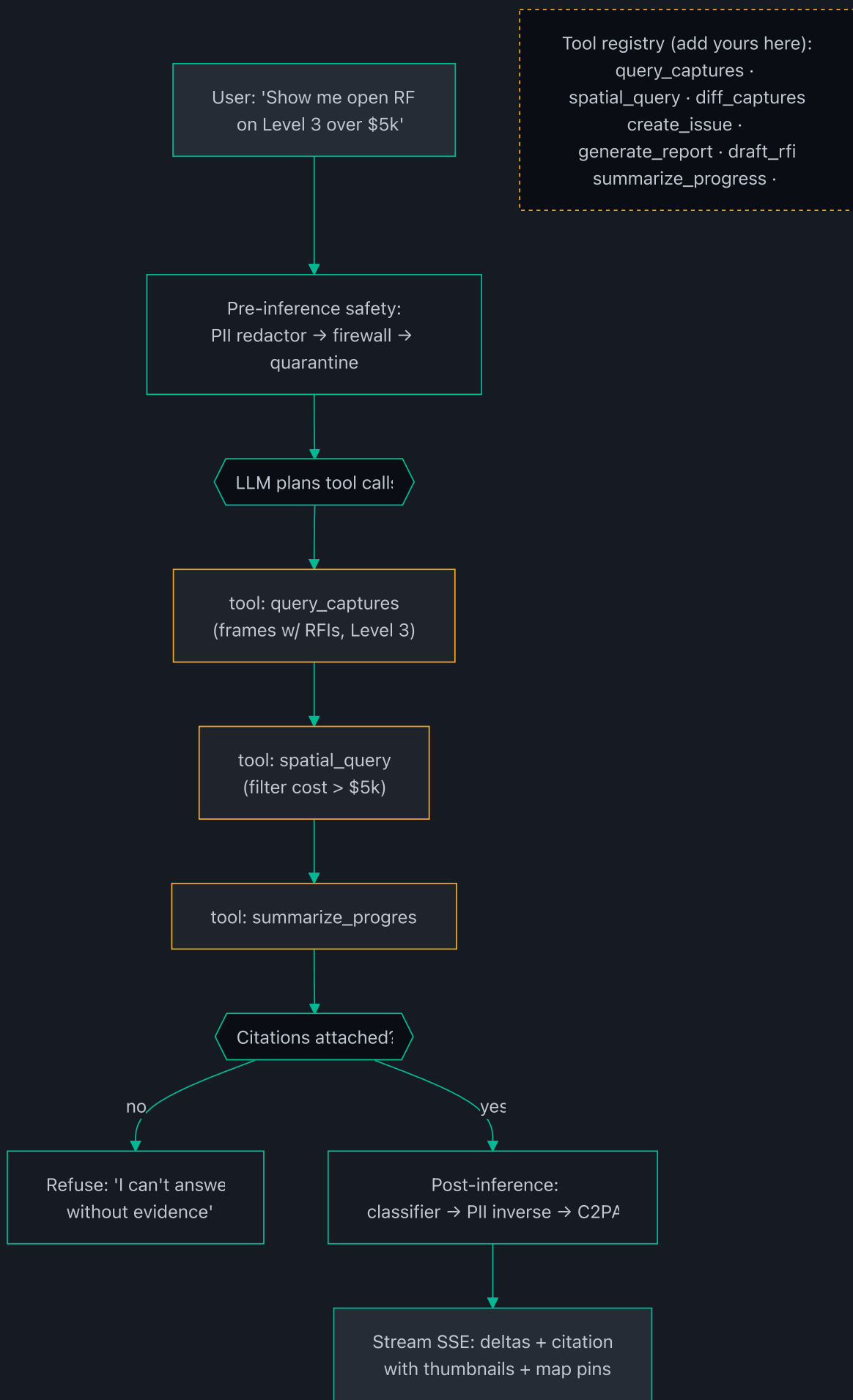
Developer rules:

- DINOv2 ViT-L/14 embeds frames, floorplans, and BIM in one space; PnP with floorplan priors recovers pose; ICP aligns to BIM mesh.

- Output carries β -distributed confidence intervals — never a bare number.
- Quality gate: $\pm 3\%$ abs / $\pm 5\%$ rel vs hand-counted baseline. Runs in CI on synthetic fixtures.
- Reproducible: seeded runs; every artifact persisted.

6. AI Copilot Function-Calling Loop

How Copilot answers "Show me open RFIs on Level 3 over \$5k" — with citations and guardrails.

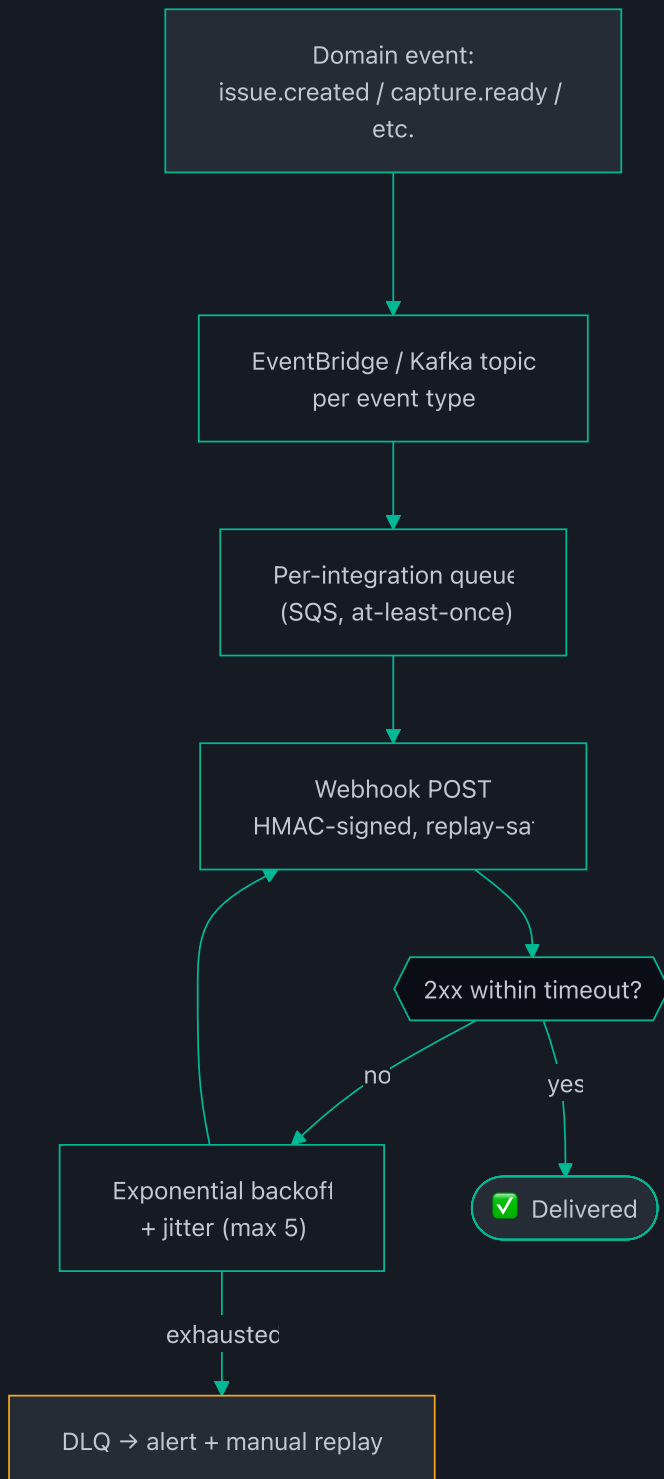


Developer rules:

- ****Refusal-on-no-citation****: if the LLM's answer can't cite a project artifact, refuse. No exceptions.
- Tool registry is open — add tools in `services/copilot-service/src/tools/` (query_captures, spatial_query, diff_captures, create_issue, generate_report, draft_rfi, summarize_progress, measure).
- Pre-inference: PII redactor → prompt firewall → context quarantine. Post-inference: content classifier → PII inverse → C2PA provenance stamp.
- All inference is tenant-pinned (no cross-tenant context ever).

7. Webhook Delivery (Reliable, Replayable)

Every domain event can fan out to partner integrations. Delivery must be at-least-once with audit.



Webhook SLA tiers:

- Public: best-effort
- Partner: 24h delivery guarantee
- Enterprise: 99.9% + replay + audit trail

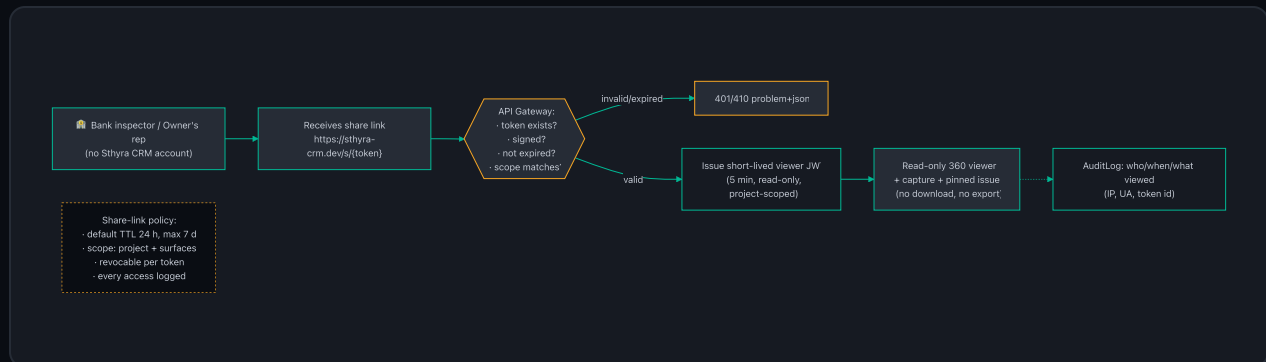
Developer rules:

- HMAC-signed payloads; signature header `X-Sthyra CRM-Signature`; replay via `X-Sthyra CRM-Event-Id` dedup.
- Exponential backoff + jitter, max 5 attempts, then DLQ + alert.

- SLA tiers: Public (best-effort) / Partner (24 h delivery) / Enterprise (99.9% + replay + audit trail).

8. Share-Link Access (External Read-Only)

Owner's reps and bank inspectors have no account. Share links give scoped, expiring, revocable access.



Developer rules:

- Token = signed, scoped (project + surfaces), default TTL 24 h / max 7 d, revocable per-token.
- Exchange token → short-lived (5 min) read-only viewer JWT. No download, no export.
- Every access logged: token id, IP, UA, timestamp → AuditLog.

9. Tenant Isolation — Every Data Plane

Multi-tenancy is enforced at six layers, not just the API. This is the architecture's most important security invariant.

Request from tenant A
user (JWT: tenant_id=A)

Golden rule: tenant isolation is
tested across
search, vectors, caches,
analytics, logs, exports —
the known leakage paths. Not
just the primary API.

Every data plane enforces tenant — not just the AP

API layer:
JWT tenant_id → context

PostgreSQL:
ROW LEVEL SECURITY
current_setting('app.tenant_id'
→ rows auto-filtered

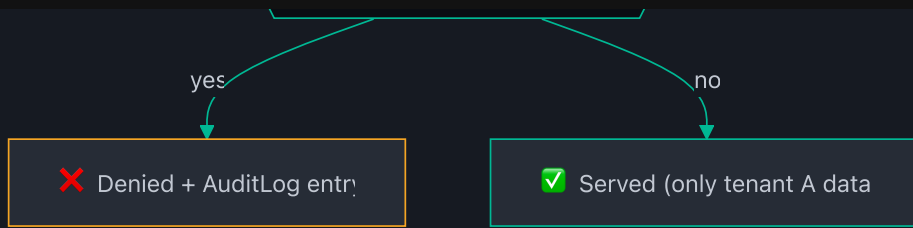
Redis:
keys prefixed tenant:A:
ACL denies other prefixes

S3:
tenant_id in key +
per-tenant access point

OpenSearch:
tenant field filter
+ index alias per tenant

KMS:
per-tenant CMK
envelope encryptor

Cross-tenant access attempter



Developer rules:

- Postgres: RLS on every table using `current_setting('app.tenant_id')` — set at connection pool checkout.
- Redis: keys prefixed `tenant::` + ACLs; S3: tenant in key + per-tenant access points; OpenSearch: tenant filter + alias; KMS: per-tenant CMK.
- ****Test tenant isolation across search, vectors, caches, analytics, logs, and exports**** — the known leakage paths. Not just the primary API.

10. Progress Pipeline (Capture → Dashboard)

From `capture.ready` to the EV S-curve on the dashboard, in one event-driven flow.



Developer rules:

- Consume `capture.ready` events; never trigger on a schedule.
- Per-element installed booleans → trade/floor aggregation with CI → schedule risk (critical path + weather).
- Emit `progress.updated` → dashboard refresh + notifications. Snapshots are immutable + reproducible.

Implementation checklist for each flow

| Flow | Package/service | Test seam | Verify with |

|---|---|---|---|

| 1 Auth | `packages/auth` , `services/user-service` | `verifyToken` option | `pnpm --filter=@sthyra-crm/auth test` |

| 2 Capture | `services/capture-service` (P1) | FakePgClient + Step Functions mock | `pnpm --filter=@sthyra-crm/capture-service test` |

| 3 Sync | `apps/mobile-kmm` (P1) | JVM unit tests + mocked remote | `gradle :mobile-kmm:jvmTest` |

| 4 Issues | `services/field-service` (P1) | Event capture on service | Event emitted assertions |

| 5 Alignment | `services/imgproc-service` (P1) | Synthetic Blender fixtures | CI numerical gate ±3/±5% |

| 6 Copilot | [services/copilot-service](#) (P2) | Red-team + hallucination eval | Citation-faithfulness suite |

| 7 Webhooks | [services/integration-hub](#) (P2) | Mock webhook endpoint | Retry/DLQ tests |

| 8 Share links | [services/user-service](#) | Token mint/verify unit tests | 401/410 on expired |

| 9 Tenancy | All services | Cross-tenant probe tests | Isolation suite in CI |

| 10 Progress | [services/track-service](#) (P2) | Synthetic captures → snapshots | Tolerance band checks |

End of developer flow document.